

FIAP - FACULDADE DE INFORMÁTICA E ADMINISTRAÇÃO PAULISTA

Instituto especializada em tecnologia e gestão empresarial

Pós Tech de Software Architecture

Augusto Zanesco Bortoncello

Claudio Gabriel Kosooski

Daniel da Conceição Alferes

Fernando Oliveira Soares

Oéslei Ismael Kuhn

Tech Challenge - Documento de entrega

Sistema de Gestão de Oficina Mecânica

Grupo Archflow

Digital e hands-on

Turma Online

2026



FIAP - FACULDADE DE INFORMÁTICA E ADMINISTRAÇÃO PAULISTA

Pós Tech de Software Architecture

FASE 1

Tech Challenge - Documento de entrega

Sistema de Gestão de Oficina Mecânica

Trabalho de pós tech apresentado ao curso de Software Architecture, como parte dos requisitos necessários à obtenção do título de conclusão da fase 1.

Orientadores: Colaborativa por todo o corpo de professores do ecossistema FIAP.

Grupo Archflow

Turma Online

2026

“Se você não jogar, jamais irá vencer”.
Charles Bukowski

Sumário

1.	Identificação do Grupo.....	6
2.	Links do Projeto.....	7
2.1.	Documentação.....	7
2.2.	Repositório.....	8
3.	Relatório de Análise de Vulnerabilidades	9
3.1.	Comando Utilizado.....	9
3.2.	Resultado dos Alertas	9
3.3.	Resumo das Sequências	9
3.4.	Detalhamento dos Alertas	10
3.5.	Conclusão da Análise	18

Lista de Tabelas

Tabela 1 - Participantes e usernames no Discord	6
Tabela 2 - Link da documentação.....	7
Tabela 3 - Link do repositório	8
Tabela 4 - Resultado dos Alertas.....	9
Tabela 5 - 1.1. Resumo das Sequências	9
Tabela 6 - Cabeçalho Content Security Policy (CSP) Não Definido	10
Tabela 7 - Cabeçalho Cross-Origin-Resource-Policy Ausente ou Inválido	12
Tabela 8 - Cabeçalho Permissions-Policy Não Definido.....	13
Tabela 9 - Servidor Vaza Informações via Cabeçalho HTTP "X-Powered-By"	14
Tabela 10 - Servidor Vaza Informação de Versão via Cabeçalho HTTP "Server"	15
Tabela 11 - Cabeçalho X-Content-Type-Options Ausente.....	16
Tabela 12 - Aplicação Web Moderna.....	17
Tabela 13 - Conteúdo Armazenável e Cacheável	17

1. Identificação do Grupo

Tabela 1 - Participantes e usernames no Discord

Nome Completo	RM	Username no Discord
Augusto Zanesco Bortoncello	RM374903	Augusto Bortoncello RM374903
Claudio Gabriel Kosooski	RM375013	Claudio G Kosooski RM375013
Daniel da Conceição Alferes	RM374468	Daniel Alferes RM374468
Fernando Oliveira Soares	RM374940	Fernando Oliveira RM374940
Oéslei Ismael Kuhn	RM374924	Oeslei RM374924

Fonte: A autoria própria

2. Links do Projeto

2.1. Documentação

Tabela 2 - Link da documentação

Recurso	URL / Instrução
Documentação DDD: Event Storming (Miro)	https://miro.com/app/board/uXjVHaErBw=/
Documentação DDD: Domínios e Subdomínios (Excalidraw)	https://excalidraw.com/#room=61a5deb68a5644639fe3,-UGs5VigxN_metUxdaeihg
Artefatos DDD: README e diagramas (GitHub)	https://github.com/oesleik/tech-chalange/tree/master/docs/ddd
Decisões de Arquitetura: ADRs (GitHub)	https://github.com/oesleik/tech-chalange/tree/master/docs/adr
Visão Geral da Arquitetura do Sistema (GitHub)	https://github.com/oesleik/tech-chalange/tree/master/docs/architecture
Análise de Qualidade de Código (SonarCloud)	https://sonarcloud.io/summary/new_code?id=oesleik_tech-chalange
Documentação API (Swagger / OpenAPI 3.0)	http://localhost/docs/index.html (disponível após execução local via Docker)

Fonte: Autoria própria

Nota: A documentação interativa da API (Swagger/OpenAPI 3.0) é servida pela própria aplicação e requer a execução do ambiente Docker local. Para acessá-la, clone o repositório e execute `make up` na raiz do projeto. A interface estará disponível em <http://localhost/docs/index.html>.

2.2. Repositório

Tabela 3 - Link do repositório

Recurso	URL
Repositório GitHub	https://github.com/oesleik/tech-chalange

Fonte: Autoria própria

3. Relatório de Análise de Vulnerabilidades

A análise de segurança foi realizada utilizando o OWASP ZAP (Zed Attack Proxy) na modalidade Baseline Scan, que executa varredura passiva na aplicação sem realizar ataques ativos. A ferramenta foi executada via container Docker oficial apontando para o ambiente local em execução.

3.1. Comando Utilizado

```
make security-scan
```

3.2. Resultado dos Alertas

Tabela 4 - Resultado dos Alertas

Nível de Risco	Qtd. de Alertas	Observação
 High (Alto)	0	Nenhuma vulnerabilidade crítica encontrada
 Medium (Médio)	1	CSP Header não configurado
 Low (Baixo)	5	Headers de segurança ausentes / vazamento de versão
 Informational (Informativo)	2	Sem impacto de segurança direto
☐ False Positives	0	Nenhum falso positivo registrado

Fonte: Autoria própria

3.3. Resumo das Sequências

Tabela 5 - 1.1. Resumo das Sequências

#	ID ZAP	Alerta	Risco	Instâncias
1	10038	Content Security Policy (CSP) Header Not Set: ausência do header CSP, que protege contra XSS e injeção de dados. Detectado em	 Médio	2

		/robots.txt e /sitemap.xml.		
2	90004	Cross-Origin-Resource-Policy Header Missing: ausência do header CORP, que controla quais origens podem carregar os recursos da aplicação.	● Baixo	1
3	10063	Permissions Policy Header Not Set: ausência do header que restringe acesso a recursos do navegador (câmera, microfone, etc.).	● Baixo	2
4	10037	X-Powered-By Header Leak: o PHP expõe sua versão exata (PHP/8.4.22) no header de resposta, revelando informações da stack.	● Baixo	3
5	10036	Server Version Leak via 'Server' Header: o Nginx expõe sua versão exata (nginx/1.31.0), facilitando ataques direcionados.	● Baixo	3
6	10021	X-Content-Type-Options Header Missing: ausência do header nosniff, permitindo MIME-sniffing em browsers mais antigos.	● Baixo	1
7	10109	Modern Web Application: aviso informativo — o ZAP identificou a aplicação como moderna. Nenhuma ação necessária.	● Info	2
8	10049	Storable and Cacheable Content: respostas sem diretiva explícita de cache podem ser armazenadas por proxies intermediários.	● Info	3

Fonte: Autoria própria

3.4. Detalhamento dos Alertas

● Médio

Cabeçalho Content Security Policy (CSP) Não Definido

Tabela 6 - Cabeçalho Content Security Policy (CSP) Não Definido

Descrição	O Content Security Policy (CSP) é uma camada adicional de segurança que ajuda a detectar e mitigar ataques como Cross-Site Scripting (XSS) e injeção de dados. O CSP fornece cabeçalhos HTTP padrão que permitem declarar
-----------	---

	fontes de conteúdo aprovadas para JavaScript, CSS, frames HTML, fontes, imagens e objetos incorporáveis.
URL	http://localhost/robots.txt http://localhost/sitemap.xml
Método	GET
Parâmetro	—
Ataque	—
Evidência	—
Outras Informações	—
Instâncias	2
Solução	Certifique-se de que o servidor web, servidor de aplicação, balanceador de carga, etc. esteja configurado para definir o cabeçalho Content-Security-Policy.
Referências	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Fonte: Autoria própria

● Baixo

Cabeçalho Cross-Origin-Resource-Policy Ausente ou Inválido

Tabela 7 - Cabeçalho Cross-Origin-Resource-Policy Ausente ou Inválido

Descrição	O cabeçalho Cross-Origin-Resource-Policy é um cabeçalho opcional projetado para neutralizar ataques de canal lateral como o Spectre. O recurso deve ser explicitamente definido como compartilhável entre diferentes origens.
URL	http://localhost/
Método	GET
Parâmetro	Cross-Origin-Resource-Policy
Ataque	—
Evidência	—
Outras Informações	—
Instâncias	1
Solução	Certifique-se de que o servidor web define o cabeçalho Cross-Origin-Resource-Policy como 'same-origin' para todas as páginas. O valor 'same-site' é considerado menos seguro. Se os recursos precisarem ser compartilhados entre origens, utilize 'cross-origin'.
Referências	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Fonte: Autoria própria

● Baixo

Cabeçalho Permissions-Policy Não Definido

Tabela 8 - Cabeçalho Permissions-Policy Não Definido

Descrição	O cabeçalho Permissions-Policy restringe o acesso não autorizado a funcionalidades do navegador por recursos web (câmera, microfone, localização, tela cheia etc.), garantindo a privacidade do usuário.
URL	http://localhost/robots.txt http://localhost/sitemap.xml
Método	GET
Parâmetro	—
Ataque	—
Evidência	—
Outras Informações	—
Instâncias	2
Solução	Certifique-se de que o servidor web, servidor de aplicação, balanceador de carga, etc. esteja configurado para definir o cabeçalho Permissions-Policy.
Referências	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Fonte: Autoria própria

● Baixo

Servidor Vaza Informações via Cabeçalho HTTP "X-Powered-By"

Tabela 9 - Servidor Vaza Informações via Cabeçalho HTTP "X-Powered-By"

Descrição	O servidor está vazando informações por meio do cabeçalho X-Powered-By, facilitando que invasores identifiquem frameworks e componentes da aplicação e suas possíveis vulnerabilidades.
URL	http://localhost/ http://localhost/robots.txt http://localhost/sitemap.xml
Método	GET
Parâmetro	—
Ataque	—
Evidência	X-Powered-By: PHP/8.4.22
Outras Informações	—
Instâncias	3
Solução	Certifique-se de que o servidor web, servidor de aplicação, balanceador de carga, etc. esteja configurado para suprimir os cabeçalhos X-Powered-By.
Referências	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Fonte: Autoria própria

● Baixo

Servidor Vaza Informação de Versão via Cabeçalho HTTP "Server"

Tabela 10 - Servidor Vaza Informação de Versão via Cabeçalho HTTP "Server"

Descrição	O servidor está vazando a versão exata do Nginx pelo cabeçalho Server, facilitando que invasores identifiquem vulnerabilidades conhecidas nessa versão específica.
URL	http://localhost/ http://localhost/robots.txt http://localhost/sitemap.xml
Método	GET
Parâmetro	—
Ataque	—
Evidência	nginx/1.31.0
Outras Informações	—
Instâncias	3
Solução	Certifique-se de que o servidor web esteja configurado para suprimir o cabeçalho Server ou fornecer apenas informações genéricas.
Referências	https://httpd.apache.org/docs/current/mod/core.html#server-tokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Fonte: Autoria própria

● Baixo

Cabeçalho X-Content-Type-Options Ausente

Tabela 11 - Cabeçalho X-Content-Type-Options Ausente

Descrição	O cabeçalho X-Content-Type-Options não foi definido como 'nosniff'. Isso permite que versões antigas do Internet Explorer e Chrome realizem MIME-sniffing no corpo da resposta, podendo interpretá-la como um tipo de conteúdo diferente do declarado.
URL	http://localhost/
Método	GET
Parâmetro	x-content-type-options
Ataque	—
Evidência	—
Outras Informações	Este problema também se aplica a páginas de erro (401, 403, 500 etc.). No limiar 'High', esta regra não alerta sobre respostas de erro do cliente ou servidor.
Instâncias	1
Solução	Defina o cabeçalho X-Content-Type-Options como 'nosniff' para todas as páginas web, garantindo que o Content-Type seja respeitado pelos navegadores.
Referências	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Fonte: Autoria própria

● Informativo

Aplicação Web Moderna

Tabela 12 - Aplicação Web Moderna

Descrição	A aplicação parece ser uma aplicação web moderna. Caso seja necessário explorá-la automaticamente, o Ajax Spider pode ser mais eficaz do que o spider padrão.
URL	http://localhost/robots.txt http://localhost/sitemap.xml
Método	GET
Parâmetro	—
Ataque	—
Evidência	Go Back
Outras Informações	Foram encontrados links sem atributos href tradicionais, o que indica tratar-se de uma aplicação web moderna.
Instâncias	2
Solução	Este é um alerta informativo. Nenhuma alteração é necessária.
Referências	—
CWE Id	—
WASC Id	—
Plugin Id	10109

Fonte: Autoria própria

● Informativo

Conteúdo Armazenável e Cacheável

Tabela 13 - Conteúdo Armazenável e Cacheável

Descrição	O conteúdo das respostas pode ser armazenado por servidores proxy e recuperado do cache em resposta a requisições de outros usuários. Se os dados forem sensíveis ou específicos de um usuário, isso pode resultar em vazamento de informações confidenciais ou até controle de sessão por terceiros.
URL	http://localhost/

	http://localhost/robots.txt http://localhost/sitemap.xml
Método	GET
Parâmetro	—
Ataque	—
Evidência	—
Outras Informações	Na ausência de diretiva de vida útil de cache na resposta, foi assumida uma heurística liberal de 1 ano, conforme permitido pela RFC 7234.
Instâncias	3
Solução	Se a resposta contiver dados sensíveis, utilize: Cache-Control: no-cache, no-store, must-revalidate, private / Pragma: no-cache / Expires: 0
Referências	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Fonte: Autoria própria

3.5. Conclusão da Análise

O sistema demonstrou um bom nível de segurança para um MVP, com zero vulnerabilidades de risco alto identificadas. O único alerta de risco médio (CSP) e os cinco de risco baixo estão relacionados a headers HTTP ausentes e exposição de versão, todos corrigíveis via configuração de Nginx e PHP, sem alterações no código da aplicação. Os dois alertas informativos não representam risco de segurança.

O relatório completo da varredura está disponível no repositório em: <docs/security/zap-baseline-report.html>.